

Лекция 15. Технологии обнаружения и предотвращения вторжений

Учебные вопросы:

1. Понятие системы обнаружения вторжений (IDS)
2. Классификация IDS
3. Архитектура IDS
4. Сигнатурный анализ и обнаружение аномалий
5. Обнаружение атак в реальном времени и отложенный анализ
6. Локальные и сетевые системы обнаружения атак
7. Распределенные системы обнаружения атак
8. Понятие системы предотвращения вторжений (IPS)

1. Понятие системы обнаружения вторжений (IDS)

Система обнаружения вторжения (IDS – Intrusion Detection System) являются программными или аппаратными системами, которые автоматизируют процесс просмотра событий, возникающих в компьютерной системе или сети, и анализируют их с точки зрения безопасности. Так как количество сетевых атак возрастает, IDS становятся необходимым дополнением инфраструктуры.

Первые прототипы СОВ появились в начале 1980-х годов и были ориентированы в первую очередь на защиту автономных ЭВМ, не объединенных в сеть. Обнаружение атак производилось путем анализа журналов регистрации событий постфактум. Современные системы в основном ориентированы на защиту от угроз, направленных из сети, поэтому их архитектура существенным образом поменялась. Вместе с тем основные подходы к обнаружению атак остались прежними.

Обнаружение проникновения является процессом мониторинга событий, происходящих в компьютерной системе или сети, и анализа их. Проникновения определяются как попытки компрометации

конфиденциальности, целостности, доступности или обхода механизмов безопасности компьютера или сети.

Проникновения могут осуществляться как атакующими, получающими доступ к системам из Интернета, так и авторизованными пользователями систем, пытающимися получить дополнительные привилегии, которых у них нет. IDS являются программными или аппаратными устройствами, которые автоматизируют процесс мониторинга и анализа событий, происходящих в сети или системе, с целью обнаружения проникновений.



IDS состоят из трех функциональных компонентов: информационных источников, анализа и ответа. Система получает информацию о событии из одного или более источников информации, выполняет определяемый конфигурацией анализ данных события и затем создает специальные ответы – от простейших отчетов до активного вмешательства при определении проникновений.

2. Классификация IDS

Для проведения классификации IDS необходимо учесть несколько факторов (см. Рис.1).

Метод обнаружения описывает характеристики анализатора. Когда IDS использует информацию о нормальном поведении контролируемой системы, она называется поведенческой. Когда IDS работает с информацией об атаках, она называется интеллектуальной.



Рис. 1 Характеристики систем обнаружения вторжений

Поведение после обнаружения указывает на реакцию IDS на атаки. Реакция может быть активной – IDS предпринимает корректирующие (устраняет лазейки) или действительно активные (закрывает доступ для возможных нарушителей, делая недоступными сервисы) действия. Если IDS только выдаёт предупреждения, её называют пассивной.

Расположение источников результата аудита подразделяет IDS в зависимости от вида исходной информации, которую они анализируют.

Входными данными для них могут быть результаты аудита, системные регистрационные файлы или сетевые пакеты.

Частота использования отражает либо непрерывный мониторинг контролируемой системы со стороны IDS, либо соответствующие периодическим запускам IDS для проведения анализа.

Классифицировать IDS можно также по нескольким параметрам (см. Рис.2).



Рис. 2 Классификация систем обнаружения вторжений

По способам реагирования различают статические и динамические IDS.

Статические средства делают «снимки» (snapshot) среды и осуществляют их анализ, разыскивая уязвимое ПО, ошибки в конфигурациях и т.д. Статические IDS проверяют версии работающих в системе приложений на наличие известных уязвимостей и слабых паролей, проверяют содержимое специальных файлов в директориях пользователей или проверяют конфигурацию открытых сетевых сервисов. Статические IDS обнаруживают следы вторжения. Динамические IDS осуществляют мониторинг в реальном времени всех действий, происходящих в системе, просматривая файлы аудита или сетевые пакеты, передаваемые за определённый промежуток времени. Динамические IDS реализуют анализ в реальном времени и позволяют постоянно следить за безопасностью системы.

По способу сбора информации различают сетевые и системные IDS.

Сетевые (NIDS) контролируют пакеты в сетевом окружении и обнаруживают попытки злоумышленника проникнуть внутрь защищаемой системы или реализовать атаку «отказ в обслуживании». Эти IDS работают с сетевыми потоками данных. Типичный пример NIDS – система, которая контролирует большое число TPC-запросов на

соединение (SYN) со многими портами на выбранном компьютере, обнаруживая, таким образом, что кто-то пытается осуществить сканирование TCP-портов. Сетевая IDS может запускаться либо на отдельном компьютере, который контролирует свой собственный трафик, либо на выделенном компьютере, прозрачно просматривающим весь трафик в сети (концентратор, маршрутизатор). Сетевые IDS контролируют много компьютеров, тогда как другие IDS контролируют только один. IDS, которые устанавливаются на хосте и обнаруживают злонамеренные действия на нём называются хостовыми или системными IDS. Примерами хостовых IDS могут быть системы контроля целостности файлов (СКЦФ), которые проверяют системные файлы с целью определения, когда в них были внесены изменения. Мониторы регистрационных файлов (Log-file monitors, LFM), контролируют регистрационные файлы, создаваемые сетевыми сервисами и службами.

Обманные системы, работающие с псевдосервисами, цель которых заключается в воспроизведении хорошо известных уязвимостей для обмана злоумышленников.

По методам анализа IDS делят на две группы: IDS, которые сравнивают информацию с предустановленной базой сигнатур атак и IDS, контролирующие частоту событий или обнаружение статистических аномалий.

Анализ сигнатур был первым методом, примененным для обнаружения вторжений. Он базируется на простом понятии совпадения последовательности с образцом. Во входящем пакете просматривается байт за байтом и сравнивается с сигнатурой (подписью) – характерной строкой программы, указывающей на характеристику вредного трафика. Такая подпись может содержать ключевую фразу или команду, которая связана с нападением. Если совпадение найдено, объявляется тревога.

Второй метод анализа состоит в рассмотрении строго форматированных данных трафика сети, известных как протоколы. Каждый пакет сопровождается различными протоколами. Авторы IDS, зная это, внедрили инструменты, которые разворачивают и осматривают эти протоколы, согласно стандартам. Каждый протокол имеет несколько полей с ожидаемыми или нормальными значениями. Если что-нибудь нарушает эти стандарты, то вероятно злонамеренность. IDS просматривает каждое поле всех протоколов входящих пакетов: IP, TCP, и UDP.

Если имеются нарушения протокола, например, если он содержит неожиданное значение в одном из полей, объявляется тревога.

Системы анализа сигнатуры имеют несколько важных сильных сторон. Во-первых, они очень быстры, так как полный анализ пакета – относительно тяжелая задача. Правила легко написать, понять и настроить. Кроме того, имеется просто фантастическая поддержка компьютерного сообщества в быстром производстве сигнатур для новых опасностей. Эти системы превосходят все другие при отлове хакеров на первичном этапе: простые атаки имеют привычку использовать некие предварительные действия, которые легко распознать.

Наконец, анализ, основанный на сигнатуре, точно и быстро сообщает, что в системе все нормально (если это действительно так), поскольку должны произойти некие особые события для объявления тревоги.

С другой стороны IDS, основывающаяся только на анализе сигнатур, имеет определенные слабости. Являясь первоначально очень быстрой, со временем скорость ее работы будет замедляться, поскольку возрастает число проверяемых сигнатур. Это – существенная проблема, поскольку число проверяемых сигнатур может расти очень быстро. Фактически, каждая новая атака или действие,

придуманное атакующим, увеличивает список проверяемых сигнатур. Не помогут даже эффективные методы работы с данными и пакетами: огромное количество слегка измененных атак могут проскользнуть через такую систему.

Имеется и другая сторона проблемы: так как система работает, сравнивая список имеющихся сигнатур с данными пакета, такая IDS может выявить только уже известные атаки, сигнатуры которых имеются.

3. Архитектура IDS

Архитектура IDS определяет, какие имеются функциональные компоненты IDS и как они взаимодействуют друг с другом. Основными архитектурными компонентами являются: Host – система, на которой выполняется ПО IDS, и Target – система, за которой IDS наблюдает.

У систем обнаружения вторжений целесообразно различать локальную и глобальную архитектуру.

В рамках локальной архитектуры реализуются элементарные составляющие, которые затем могут быть объединены для обслуживания корпоративных систем.

Основные элементы локальной архитектуры и связи между ними показаны на рисунке 3. Первичный сбор данных осуществляют агенты, называемые также сенсорами. Регистрационная информация может извлекаться из системных или прикладных журналов (технически несложно получать ее и напрямую от ядра ОС), либо добываться из сети с помощью соответствующих механизмов активного сетевого оборудования или путем перехвата пакетов посредством установленной в режим мониторинга сетевой карты.



Рис. 3 Основные элементы локальной архитектуры систем обнаружения вторжений.

На уровне агентов (сенсоров) может выполняться фильтрация данных с целью уменьшения их объема. Это требует от агентов некоторого интеллекта, но зато разгружает остальные компоненты системы.

Агенты передают информацию в центр распределения, который приводит ее к единому формату, возможно, осуществляет дальнейшую фильтрацию, сохраняет в базе данных и направляет для анализа статистическому и экспертному компонентам. Один центр распределения может обслуживать несколько сенсоров. Содержательный активный аудит начинается со статистического и экспертного компонентов. Если в процессе статистического или экспертного анализа выявляется подозрительная активность, соответствующее сообщение направляется решателю, который

определяет, является ли тревога оправданной, и выбирает способ реагирования.

Хорошая система обнаружения вторжений должна уметь внятно объяснить, почему она подняла тревогу, насколько серьезна ситуация и каковы рекомендуемые способы действия. Если выбор должен оставаться за человеком, то пусть он сводится к нескольким элементам меню, а не к решению концептуальных проблем.

Глобальная архитектура подразумевает организацию одноранговых и разноранговых связей между локальными системами обнаружения вторжений (см. Рис.4).

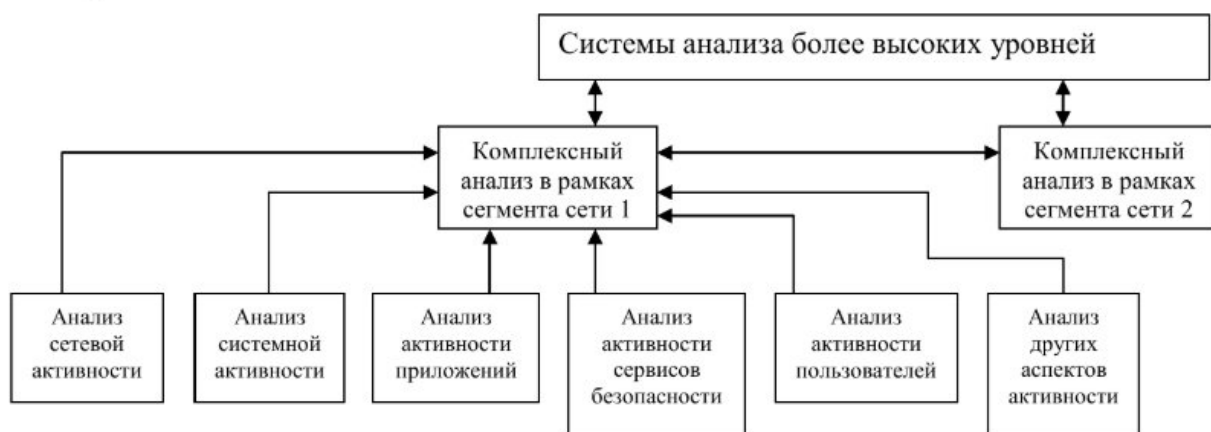


Рис. 4 Глобальная архитектура систем обнаружения вторжений

На одном уровне иерархии располагаются компоненты, анализирующие подозрительную активность с разных точек зрения. Например, на хосте могут располагаться подсистемы анализа поведения пользователей и приложений. Их может дополнять подсистема анализа сетевой активности. Когда один компонент обнаруживает что-то подозрительное, то во многих случаях целесообразно сообщить об этом соседям либо для принятия мер, либо для усиления внимания к определенным аспектам поведения системы. Разноранговые связи используются для обобщения результатов анализа и получения

целостной картины происходящего. Иногда у локального компонента недостаточно оснований для возбуждения тревоги, но «по совокупности» подозрительные ситуации могут быть объединены и совместно проанализированы, после чего порог подозрительности окажется превышенным. Целостная картина, возможно, позволит выявить скоординированные атаки на разные участки информационной системы и оценить ущерб в масштабе организации.

4. Сигнатурный анализ и обнаружение аномалий

Существует два основных подхода к анализу событий для определения атак: определение злоупотреблений (misuse detection) и определение аномалий (anomaly detection).

В технологии определения злоупотреблений известно, какая последовательность данных является признаком атаки. Анализ событий состоит в определении таких «плохих» последовательностей данных.

Технология определения злоупотреблений используется в большинстве коммерческих систем.

В технологии определения аномалий известно, что представляет собой

«нормальная» деятельность и «нормальная» сетевая активность. Анализ событий состоит в попытке определить аномальное поведение пользователя или аномальную сетевую активность. Данная технология на сегодняшний день является предметом исследований и используется в ограниченной форме небольшим числом IDS. Существуют сильные и слабые стороны, связанные с каждым подходом; считается, что наиболее эффективные IDS применяют в основном определение злоупотреблений с небольшими компонентами определения аномалий.

Определение злоупотреблений

Детекторы злоупотреблений анализируют деятельность системы, анализируя событие или множество событий на соответствие заранее определенному образцу, который описывает известную атаку. Соответствие образца известной атаке называется сигнатурой, определение злоупотребления иногда называют «сигнатурным определением».

Наиболее общая форма определения злоупотреблений, используемая в коммерческих продуктах, специфицирует каждый образец событий, соответствующий атаке, как отдельную сигнатуру. Тем не менее существует несколько более сложных подходов для выполнения определения злоупотреблений (называемых state-based технологиями анализа), которые могут использовать единственную сигнатуру для определения группы атак.

Преимущества сигнатурного метода:

~ Детекторы злоупотреблений являются очень эффективными для определения атак и не создают при этом огромного числа ложных сообщений.

~ Детекторы злоупотреблений могут быстро и надежно диагностировать использование конкретного инструментального средства или технологии атаки. Это может помочь администратору скорректировать меры обеспечения безопасности.

~ Детекторы злоупотреблений позволяют администраторам, независимо от уровня их квалификации в области безопасности, начать процедуры обработки инцидента.

Недостатки сигнатурного метода:

~ Детекторы злоупотреблений могут определить только те атаки, о которых они знают, следовательно, надо постоянно обновлять их базы данных для получения сигнатур новых атак.

~ Многие детекторы злоупотреблений разработаны таким образом, что могут использовать только строго определенные

сигнатуры, а это не допускает определения вариантов общих атак. State-based детекторы злоупотреблений могут обойти данное ограничение, но они применяются в коммерческих IDS не столь широко.

Определение аномалий

Детекторы аномалий определяют ненормальное (необычное) поведение на хосте или в сети. Они предполагают, что атаки отличаются от «нормальной» (законной) деятельности и могут, следовательно, быть определены системой, которая умеет отслеживать эти отличия. Детекторы аномалий создают профили, представляющие собой нормальное поведение пользователей, хостов или сетевых соединений. Эти профили создаются, исходя из данных истории, собранных в период нормального функционирования. Затем детекторы собирают данные о событиях и используют различные метрики для определения того, что анализируемая деятельность отклоняется от нормальной.

Метрики и технологии, используемые при определении аномалий, включают:

~ определение допустимого порога. В этом случае основные атрибуты поведения пользователя и системы выражаются в количественных терминах. Для каждого атрибута определяется некоторый уровень, который устанавливается как допустимый. Такие атрибуты поведения могут определять число файлов, доступных пользователю в данный период времени, число неудачных попыток входа в систему, количество времени ЦП, используемое процессом и т.п. Данный уровень может быть статическим или эвристическим – например, может определяться изменением анализируемых значений.

~ статистические метрики: параметрические, при которых предполагается, что распределение атрибутов профиля соответствует конкретному образцу, и непараметрические, при которых распределение атрибутов профиля является «обучаемым» исходя из

набора значений истории, которые наблюдались за определенный период времени.

~ метрики, основанные на правилах, которые аналогичны непараметрическим статистическим метрикам в том, что наблюдаемые данные определяют допустимые используемые образцы, но отличаются от них в том, что эти образцы специфицированы как правила, а не как численные характеристики.

~ другие метрики, включая нейросети, генетические алгоритмы и модели иммунных систем.

Только первые две технологии используются в современных коммерческих IDS.

К сожалению, детекторы аномалий и IDS, основанные на них, часто создают большое количество ложных сообщений, так как образцы нормального поведения пользователя или системы могут быть очень неопределенными. Несмотря на этот недостаток, исследователи предполагают, что IDS, основанные на аномалиях, имеют возможность определять новые формы атак, в отличие от IDS, основанных на сигнатурах, которые полагаются на соответствие образцу прошлых атак.

Более того, некоторые формы определения аномалий создают выходные

данные, которые могут быть далее использованы в качестве источников информации для детекторов злоупотреблений. Например, детектор аномалий, основанный на пороге, может создавать диаграмму, представляющую собой «нормальное» количество файлов, доступных конкретному пользователю; детектор злоупотреблений может использовать данную диаграмму как часть сигнатуры обнаружения, которая говорит: «если количество файлов, доступных данному пользователю, превышает данную «нормальную» диаграмму более чем на 10%, следует инициировать предупреждающий сигнал».

Хотя некоторые коммерческие IDS включают ограниченные формы определения аномалий, мало кто полагается исключительно на данную технологию. Определение аномалий, которое существует в коммерческих системах, обычно используется для определения зондирования сети или сканирования портов. Тем не менее определение аномалий остается предметом исследований в области активного определения проникновений, и скорее всего будет играть возрастающую роль в IDS следующих поколений.

Преимущества определения аномалий:

- IDS, основанные на определении аномалий, обнаруживают неожиданное поведение и, таким образом, имеют возможность определить симптомы атак без знания конкретных деталей атаки.
- Детекторы аномалий могут создавать информацию, которая в дальнейшем будет использоваться для определения сигнатур для детекторов злоупотреблений.

Недостатки определения аномалий:

- Подходы определения аномалий обычно создают большое количество ложных сигналов при непредсказуемом поведении пользователей и непредсказуемой сетевой активности.
- Подходы определения аномалий часто требуют некоторого этапа обучения системы, во время которого определяются характеристики нормального поведения.

Проверка целостности файлов

Проверки целостности файлов являются другим классом инструментальных средств безопасности, которые дополняют IDS. Эти инструментальные средства используют дайджест сообщений или другие криптографические контрольные суммы для критичных файлов и объектов, сравнивая их с хранимыми значениями и оповещая о любых различиях или изменениях.

Использование криптографических контрольных сумм важно, так как атакующие часто изменяют системные файлы по трем причинам. Во-первых, изменение системных файлов могут быть целью атаки (например, размещение Троянских программ), во-вторых, атакующие могут пытаться оставить лазейку (back door) в систему, через которую они смогут снова войти в систему позднее, и, наконец, они пытаются скрыть свои следы, чтобы собственники системы не смогли обнаружить атаку.

Хотя проверка целостности файлов часто используется для определения, были ли изменены системные или выполняемые файлы, такая проверка может также помочь определить, применялись ли модификации для исправления ошибок к программам конкретных производителей или системным файлам. Это также является очень ценным при судебных разбирательствах, так как позволяет быстро и надежно диагностировать следы атаки. Она дает возможность менеджерам оптимизировать восстановление сервиса после произошедшего инцидента.

Основные подходы к обнаружению атак практически не изменились за последнюю четверть века, и, несмотря на громкие заявления разработчиков, можно с уверенностью утверждать, что концептуально обнаружение атак базируется либо на методах сигнатурного анализа, либо на методах обнаружения аномалий. Возможно также совместное использование указанных выше методов. Сигнатурный анализ основан на предположении, что сценарий атаки известен и попытка ее реализации может быть обнаружена в журналах регистрации событий или путем анализа сетевого трафика. В идеале администратор информационной системы должен устранить все известные ему уязвимости. На практике, однако, данное требование

может оказаться невыполнимым, так как в результате может существенным образом пострадать функциональность ИС. Не исключено также, что человеческие и материальные затраты, необходимые для устранения этих уязвимостей, могут превысить стоимость информации, обрабатываемой системой. Системы обнаружения атак, использующие методы сигнатурного анализа, предназначены для решения обозначенной проблемы, так как в большинстве случаев позволяют не только обнаружить, но и предотвратить реализацию атаки на начальной стадии ее выполнения. Процесс обнаружения атак в данных системах сводится к поиску заранее известной последовательности событий или строки символов в упорядоченном во времени потоке информации. Механизм поиска определяется способом описания атаки. Наиболее простым является описание атаки при помощи набора правил (условий). Применительно к анализу сетевых пакетов эти правила могут включать определенные значения отдельных полей заголовка пакета (IP-адрес и порт источника или получателя, установленные флаги, размер пакета и т. д.). При анализе журналов регистрации событий правила могут ограничивать время регистрации пользователя в системе, количество попыток неправильного ввода пароля в течение короткого промежутка времени, а также наличие изменений в критических файлах системы. Таким образом, описание атаки отражает, во-первых, характер передаваемой информации и, во-вторых, совокупность реакций системы на реализацию атаки. Если описать текущее состояние информационной системы совокупностью пар атрибут-значение, а события представить как действия, связанные с изменением этих атрибутов, то для описания атаки может использоваться теория конечных автоматов. В этом случае реализации каждой атаки соответствует последовательность переходов из «исходного» состояния системы в ее «конечное» состояние, характеризующее реализацию данной атаки. Условия и

направление перехода определяются набором правил, как было описано выше. Такой подход к описанию сценария атаки является более точным, чем описание при помощи набора правил, так как позволяет учитывать динамику развития атаки и выявлять попытки реализации атак, скрытых в интенсивном потоке событий, сгенерированных злоумышленником для прикрытия своих истинных намерений. Применение методов сигнатурного анализа требует от разработчика СОА выбора или создания специального языка, позволяющего описывать регистрируемые системой события, а также устанавливать соответствия между ними. Универсальность и полнота этого языка являются определяющими факторами эффективной работы системы обнаружения, так как в конечном счете на этом языке будут сформулированы правила, по которым выявляется атака. Реагирование на попытку реализации атаки может включать как простое извещение администратора информационной системы, так и более активные меры: разрыв установленного соединения, отключение уязвимой службы, перепрограммирование межсетевого экрана на отклонение пакетов, полученных от выявленного системой злоумышленника, а также другие меры, препятствующие «успешному» завершению атаки. Все СОА, использующие метод обнаружения атак по сигнатуре, имеют в своем составе базу данных известных атак (их сигнатур). Очевидно, что к принципиальным недостаткам рассматриваемого класса СОА относится не возможность обнаружения атак, сигнатуры которых отсутствуют в базе данных. Поэтому, чтобы обеспечить эффективную работу системы обнаружения, эта база должна регулярно обновляться. Обычно возможность обновления, в том числе автоматического, предусмотрена разработчиками системы. Преимуществами систем, использующих сигнатурный анализ, являются низкая вероятность «ложной тревоги» (ошибочного обнаружения атаки при ее фактическом отсутствии), а также

относительная простота настройки. Подход к обнаружению атак, основанный на попытке обнаружения аномального поведения системы, также был впервые предложен в 1980-х годах. Основной предпосылкой применения указанного подхода является то, что в процессе «штатного» функционирования информационная система находится в некотором равновесном состоянии. Попытка реализации атаки ведет к выходу системы из этого состояния, причем факт выхода может быть зафиксирован. При создании СОА, работающих по принципу обнаружения аномалий, должны быть решены три задачи. Во-первых, необходимо разработать способ описания состояния информационной системы. Это нетривиальная задача, так как должна быть учтена как статическая, так и динамическая составляющие. Например, должны быть описаны типичные для системы потоки данных, передаваемых по сети. Во-вторых, необходимо разработать алгоритмы, при помощи которых будет автоматически (или с вмешательством администратора) составляться описание реальной работающей системы — ее «профиль». Это нужно для того, чтобы «научить» СОА различать штатный режим работы информационной системы. В-третьих, необходимо выбрать математические методы, которые будут использоваться для обнаружения аномалий в процессе функционирования системы. Другими словами, должны быть определены механизмы принятия решения о попытке атаки защищаемой системы. Очевидно, что используемые механизмы принятия решения в первую очередь зависят от того, как была описана система. Рассмотрим простой пример. Пусть одним из параметров информационной системы является количество отклоненных входящих TCP-соединений, а точнее — среднее значение и дисперсия указанного параметра. В случае штатной работы системы количество отклоняемых соединений должно быть незначительным. Если злоумышленник начнет исследовать уязвимость системы при помощи сканирования

портов, то есть попытается реализовать атаку «сканирование портов», количество отклоненных TCP-соединений резко воз растет. Такой скачок может быть обнаружен различными способами. Во-первых, может быть применен статистический критерий равенства средних значений двух случайных величин. Для его использования, правда, необходимо сделать два достаточно неоднозначных предположения: о нормальности распределений случайных величин и о равенстве их дисперсий. Во-вторых, что представляется более уместным, могут быть применены математические методы, известные под общим названием «методов обнаружения разладки». Эти методы специально разрабатывались для решения подобного класса задач, первоначально связанных с контролем систем слежения и управления. В-третьих, могут применяться математические методы распознавания образов. Известны также разработки, использующие нейросетевые методы анализа, однако о практическом внедрении этих методов в коммерческих программных продуктах до сих пор не сообщается. Основным преимуществом использования подхода, основанного на обнаружении аномального поведения системы, является теоретическая возможность обнаружения новых, не описанных ранее, атак. Данная возможность основана на предположении, что атака по определению представляет собой набор действий, нехарактерных для штатного режима работы системы. На сколько эффективно будут выявляться новые атаки, определяется опять же способом описания состояния системы и количеством анализируемых параметров. Большинство математических методов обнаружения, используемых в рассматриваемом классе СОА, не являются детерминированными. Это означает, что все решения принимаются на основе статистического анализа и, следовательно, могут содержать ошибки. Возможны два класса ошибок: «пропуск атаки» и «ложная тревога». Вероятность пропуска определяется характером атаки и степенью адекватности

описания текущего состояния системы. «Ложная тревога» может иметь место в том случае, если в информационной системе наблюдается нетипичная активность, являющаяся следствием действий законных пользователей (или процессов). Например, если на всех компьютерах локальной сети, имеющей подключение к Интернет, будет установлена антивирусная программа, запрограммированная на обновление антивирусных баз в одно и то же время каждые два дня, то одновременная попытка всех компьютеров подключиться к одному серверу Интернет будет интерпретироваться СОА как вирусная атака. Поэтому именно высокую вероятность «ложной тревоги» обычно называют главным недостатком систем обнаружения атак, основанных на обнаружении аномальной активности. Еще одним недостатком принято считать сложность настройки («обучения») системы, так как этот процесс требует от администратора глубоких знаний базовых принципов взаимодействия элементов информационной системы. В связи с этим полно ценных коммерческих продуктов, использующих принципы обнаружения аномальной активности, на рынке практически нет, хотя разработки этих систем непрерывно ведутся ввиду их перспективности.

5. Обнаружение атак в реальном времени и отложенный анализ

По типу обрабатываемых данных системы обнаружения атак подразделяются на «системы реального времени» и «системы отложенной обработки». Системы отложенной обработки анализируют содержимое журналов регистрации событий или массив предварительно записанного трафика, а системы реального времени — входящий поток событий от программных датчиков. Очевидно, что адекватное реагирование на попытку реализации атаки, включая ее предотвращение, возможно только при использовании систем

реального времени. В то же время это не означает, что СОА реального времени «лучше», чем системы отложенной обработки. Так, СОА реального времени, не имеющая функций по предотвращению атак, заведомо менее эффективна, чем аналогичная система с отложенной обработкой, поскольку в системе реального времени одним из основных критериев эффективности является простота используемых алгоритмов, а не их оптимальность с позиций надежности обнаружения атак. Поэтому выбор того или иного типа СОА должен делаться исходя из анализа задач, которые ставятся перед системой обнаружения.

Апостериорный анализ может использоваться со следующей целью:

- ~ расследование информационных преступлений и инцидентов;
- ~ выявление атак, не являющихся информационным преступлением (сбор информации об инфраструктуре сети, сканирование портов и пр.);
- ~ сбор информации об уязвимостях информационной системы с целью их устранения;
- ~ анализ активности отдельных пользователей;
- ~ минимизация системных требований к СОА.

Основной целью использования систем обнаружения атак реального времени является быстрое реагирование на попытки реализации атак, в том числе пресечение этих попыток. В связи с этим типичными процедурами для данных систем является анализ и фильтрация трафика на сетевом и транспортном уровнях модели OSI. Чтобы сократить производительные затраты, часто рассматриваются лишь заголовки пакетов, а их содержимое «отбрасывается». Это, очевидно, значительно сокращает перечень обнаруживаемых атак.

6. Локальные и сетевые системы обнаружения атак

Локальные и сетевые системы обнаружения атак СОА, использующие информацию, получаемую от персонального компьютера, на который они установлены, обычно называют локальными (host based). В противоположность им системы обнаружения, ориентированные на анализ всего доступного сетевого трафика, называют сетевыми (network based).

Рассмотрим, какая информация может использоваться локальными СОА для выявления попыток атаки:

~ Отслеживание попыток входящих и исходящих TCP- и UDP-соединений. В результате могут обнаруживаться и пресекаться попытки несанкционированных подключений к отдельным портам, а также попытки сканирования портов.

~ Анализ входящего и исходящего сетевого трафика на предмет наличия «подозрительных» пакетов. «Досмотру» могут подлежать как поля заголовков пакетов, так и их содержимое.

~ Отслеживание попыток регистрации на локальной ЭВМ. В случае интерактивной регистрации может накладываться ограничение на время регистрации, а в случае регистрации по сети можно ограничить перечень сетевых адресов, с которых разрешается вход в систему. Отдельное внимание уделяется множественным неудачным попыткам регистрации, которые могут иметь место в случае атаки «подбор пароля методом перебора».

~ Отслеживание активности пользователей, наделенных повышенными полномочиями в системе (суперпользователь root в UNIX-системах, пользователи группы Администраторы в ОС Windows). Так как в широком классе случаев атака направлена на получение полномочий суперпользователя, могут отслеживаться попытки регистрации этого пользователя в системе в неразрешенное время, попытки сетевой регистрации суперпользователя и т. д.

~ Проверка целостности отдельных файлов или ключей реестра (для Windows-систем). Несанкционированные действия взломщика могут заключаться в попытках внесения изменений в базу данных пользователей или в модификации отдельных настроек системы. Контроль целостности критичных областей данных позволит СОА обнаружить попытку реализации атаки. Сетевые СОА собирают и анализируют все доступные им сетевые пакеты на предмет наличия «подозрительного» содержимого или несанкционированных потоков информации от одного узла сети к другому. В связи с этим точка подключения СОА должна обеспечивать максимальный охват трафика, циркулирующего в сегменте сети. Обычно такие системы подключаются к специальному порту коммутатора либо устанавливаются непосредственно на маршрутизаторе сети. СОА данного класса гораздо эффективнее, чем локальные, способны обнаруживать факт сканирования портов, а также выявлять попытки атак на «отказ в обслуживании». Кроме того, если система обнаружения установлена на шлюзе, обеспечивающем доступ из локальной сети в Интернет, то путем фильтрации нежелательных пакетов может обеспечиваться защита этой локальной сети от внешних атак. Получается, что СОА выполняет в этом случае функции межсетевого экрана (либо управляет им). Таким образом, сетевые системы обнаружения атак находят свое применение в информационных системах, где установка специализированного программного обеспечения на компьютеры пользователей затруднительна, и там, где требуется изолировать сетевой сегмент от внешней угрозы. Необходимо отметить, что анализ интенсивного потока данных требует существенных вычислительных затрат, поэтому аппаратные требования к узлу, на котором устанавливается такая СОА, могут быть очень высокими. Наиболее критичной эта проблема становится при попытке защиты сети, содержащей несколько сотен

компьютеров и имеющей выход в Интернет. К этому классу относятся большинство сетей крупных предприятий.

7. Распределенные системы обнаружения атак

Отдельным классом систем обнаружения атак являются распределенные системы. Их основным отличием является перераспределение функций сбора данных между несколькими «агентами» — программными датчиками, установленными на узлах информационной системы. Агенты могут собирать информацию непосредственно с компьютера, на который они установлены, или анализировать данные, передаваемые по сети. Наиболее принципиальным моментом при внедрении распределенных СОА является организация информационного обмена между отдельными агентами системы. Конечной целью этого обмена является принятие решения о факте атаки.

Преимуществом использования распределенных систем является возможность собирать и анализировать значительно больший объем информации, что позволяет обнаруживать широкий спектр атак. В этом отношении наиболее эффективным является решение, объединяющее методологию локальных и сетевых СОА в единое целое. С другой стороны, распределенные системы обладают рядом недостатков, наиболее существенным из которых является меньшая защищенность их компонентов. Во-первых, сбор данных с нескольких узлов создает дополнительную нагрузку на сеть, которая, в случае полномасштабной атаки, может превысить ее пропускную способность. Во-вторых, обмен информацией по сети подразумевает наличие открытых портов, потенциально доступных для атаки на отказ в обслуживании (переполнение очереди входящих TCP-соединений). В-третьих, на узлах информационной системы возможно внедрение вредоносного программного обеспечения, которое будет блокировать

работу агента или пытаться подделывать информацию, им передаваемую. Отдельной задачей, возникающей при проектировании распределенных СОА, является выбор идеологии процедуры принятия решения. Возможны не сколько вариантов процедуры, отличающиеся степенью централизации. Наи более простым является вариант процедуры с предельной степенью централизации, когда агенты занимаются лишь сбором данных и передачей их центральному узлу СОА — модулю принятия решения. Этот модуль анализирует поступающую информацию и выносит решение о факте атаки. Данный вариант характеризуется большим объемом передаваемых по сети данных, что повышает вероятность обнаружения факта работы СОА злоумышленником и делает систему уязвимой к атакам на отказ в обслуживании. Наиболее очевидным решением по использованию такого типа СОА является их установка в рамках подсетей небольшого размера, что позволит обойти проблему пере грузки сети пакетами, сгенерированными системой. Увеличение масштабов сети требует многоступенчатого подхода к принятию решения. Он заключается в том, что выделяются промежуточные модули принятия решения, которые собирают данные только с ограниченного числа «своих» агентов и передают на верхний уровень гораздо меньший объем информации, дополненный промежуточным решением. При любом варианте реализации процедуры принятия решения очевидно, что первоочередной становится задача обеспечения защищенности самой СОА.

8. Понятие системы предотвращения вторжений (IPS)

Intrusion prevention system (IPS) – это программные и аппаратные средства, предназначенные для предотвращения вторжений. Они предназначены для обнаружения и предотвращения попыток несанкционированного доступа, использования или вывода из строя

компьютерных систем, главным образом через Интернет или локальную сеть. Такие попытки могут иметь форму как атаки хакеров или инсайдеров, так и быть результатом действий вредоносных программ.



IDS/IPS-системы используются для обнаружения аномальных действий в сети, которые могут нарушить безопасность и конфиденциальность данных, например: попытки использования уязвимостей программного обеспечения; попытки повешения привилегий; несанкционированный доступ к конфиденциальным данным; активность вредоносных программ и т.д.

Использование IPS-систем преследует несколько целей:

- ~ Обнаружить вторжение или сетевую атаку и предотвратить их;
- ~ Спрогнозировать возможные будущие атаки и выявить уязвимости для предотвращения их дальнейшего развития;
- ~ Выполнить документирование существующих угроз;
- ~ Обеспечить контроль качества администрирования с точки зрения безопасности, особенно в больших и сложных сетях;
- ~ Получить полезную информацию о проникновениях, которые имели место, для восстановления и корректирования вызвавших проникновение факторов;
- ~ Определить расположение источника атаки по отношению к локальной сети (внешние или внутренние атаки), что важно при принятии решений о расположении ресурсов в сети.

В целом, IPS аналогичны IDS. Главное же отличие состоит в том, что они функционируют в реальном времени и могут в автоматическом

режиме блокировать сетевые атаки. Каждая IPS включает в себя модуль IDS. IDS, в свою очередь, обычно состоит из:

- ~ системы сбора событий;
- ~ системы анализа собранных событий;
- ~ хранилища, в котором накапливаются собранные события и результаты их анализа;
- ~ базы данных об уязвимостях (этот параметр является ключевым, так как чем больше база у производителя, тем больше угроз способна выявлять система);
- ~ консоли управления, которая позволяет настраивать все системы, осуществлять мониторинг состояния защищаемой сети, просматривать выявленные нарушения и подозрительные действия.

По способам мониторинга IPS-системы можно разделить на две большие группы:

1. NIPS (Network Intrusion Prevention System);
2. HIPS (Host Intrusion Prevention System).

Первая группа ориентирована на сетевой уровень и корпоративный сектор, в то время как представители второй имеют дело с информацией, собранной внутри единственного компьютера, а следовательно, могут использоваться на персональных компьютерах. Сегодня HIPS часто входят в состав антивирусных продуктов.

Среди NIPS и HIPS также выделяют: Protocol-based IPS, PIPS.

Представляет собой систему (либо агент), которая отслеживает и анализирует коммуникационные протоколы со связанными системами или пользователями.

Application Protocol-based IPS, APIPS. Представляет собой систему (или агент), которая ведет наблюдение и анализ данных, передаваемых с использованием специфичных для определенных приложений протоколов.

Например, отслеживание содержимого SQL-команд. Что касается форм-фактора, IPS-системы могут быть представлены как в виде отдельного «железного» решения, так и в виде виртуальной машины или софта.

Методы реагирования:

1. После начала атаки:

~ Методы реализуются уже после того, как была обнаружена информационная атака. Это значит, что даже в случае успешного выполнения защищаемой системе может быть нанесён ущерб.

2. Блокирование соединения:

~ Если для атаки используется TCP-соединение, то реализуется его закрытие с помощью посылки каждому или одному из участников TCP-пакета с установленным флагом RST.

~ В результате злоумышленник лишается возможности продолжать атаку, используя это сетевое соединение. Данный метод, чаще всего, реализуется с помощью имеющихся сетевых датчиков.

Метод характеризуется двумя основными недостатками:

1. Не поддерживает протоколы, отличные от TCP, для которых не требуется предварительного установления соединения (например, UDP и ICMP).

2. Метод может быть использован только после того, как злоумышленник уже получил несанкционированное соединение.

3. Блокирование записей пользователей:

~ Если несколько учётных записей пользователей были скомпрометированы в результате атаки или оказались их источниками, то осуществляется их блокирование хостовыми датчиками системы. Для блокировки датчики должны быть запущены от имени учётной записи, имеющей права администратора.

~ Также блокирование может происходить на заданный срок, который определяется настройками Системы предотвращения вторжений.

4. Блокирование хоста компьютерной сети:

~ Если с одного из хостов была зафиксирована атака, то может быть произведена его блокировка хостовыми датчиками или блокирование сетевых интерфейсов либо на нём, либо на маршрутизаторе или коммутаторе, при помощи которых хост подключён к сети. Разблокирование может происходить спустя заданный промежуток времени или при помощи активации администратора безопасности. Блокировка не отменяется из-за перезапуска или отключения от сети хоста.

Так же для нейтрализации атаки можно блокировать цель, хост компьютерной сети.

5. Блокирование атаки с помощью межсетевого экрана:

~ IPS формирует и отправляет новые конфигурации в МЭ, по которым экран будет фильтровать трафик от нарушителя.

Такая реконфигурация может происходить в автоматическом режиме с помощью стандартов OPSEC (например, SAMP, CPMI).

6. Изменение конфигурации коммуникационного оборудования:

~ Для протокола SNMP, IPS анализирует и изменяет параметры из базы данных MIB (такие как таблиц маршрутизации, настройки портов) с помощью агента устройства, чтобы заблокировать атаку. Также могут использоваться протоколы TFTP, Telnet и др.

7. Активное подавление источника атаки:

~ Метод теоретически может быть использован, если другие методы окажутся бесполезны. IPS выявляет и блокирует пакеты нарушителя, и осуществляет атаку на его узел, при условии, что его

адрес однозначно определён и в результате таких действий не будет нанесён вред другим легальным узлам.

~ Так как гарантировать выполнение всех условий невозможно, широкое применение метода на практике пока невозможно.

8. В начале атаки:

~ Методы реализуют меры, которые предотвращают обнаруженные атаки до того, как они достигают цели.

9. С помощью сетевых датчиков:

~ Сетевые датчики устанавливаются в разрыв канала связи так, чтобы анализировать все проходящие пакеты. Для этого они оснащаются двумя сетевыми адаптерами, функционирующими в «смешанном режиме», на приём и на передачу, записывая все проходящие пакеты в буферную память, откуда они считываются модулем выявления атак IPS.

В случае обнаружения атаки эти пакеты могут быть удалены.

~ Анализ пакетов проводится на основе сигнатурного или поведенческого методов.

10. С помощью хостовых датчиков:

~ Удаленные атаки, реализуемые отправкой от злоумышленника серией пакетов. Защита реализуется с помощью сетевой компоненты IPS по аналогии с сетевыми датчиками, но в отличие от последних сетевая компонента перехватывает и анализирует пакеты на различных уровнях взаимодействия, что даёт предотвращать атаки по криптозащищённым IPsec- и SSL/TLS соединениям.

~ Локальные атаки при несанкционированном запуске злоумышленником программ или других действиях, нарушающих информационную безопасность. Перехватывая системные вызовы

всех приложений и анализируя их, датчики блокируют те вызовы, которые представляют опасность.